PROJET DE FIN D'ANNÉE — CMRPI

Sentinel PME

PME Cyber Threat Early Warning System

Système de détection et d'alerte précoce des cybermenaces ciblant les petites et moyennes entreprises

Documentation technique

- Fonctionnement du système
- Fonctionnalités
- Architecture logicielle
- Stack technologique
- Sécurité, tests et qualité

Version 1.0 — 09/07/2026

Année universitaire 2025-2026

1. Présentation du projet

Les PME utilisent massivement des services numériques (messagerie professionnelle, sites web, outils cloud, applications de gestion) mais disposent rarement d'un SOC, d'un SIEM ou d'une équipe de cybersécurité dédiée. Elles restent donc très exposées au phishing, aux ransomwares, aux malwares, à l'exploitation de vulnérabilités et aux attaques par force brute.

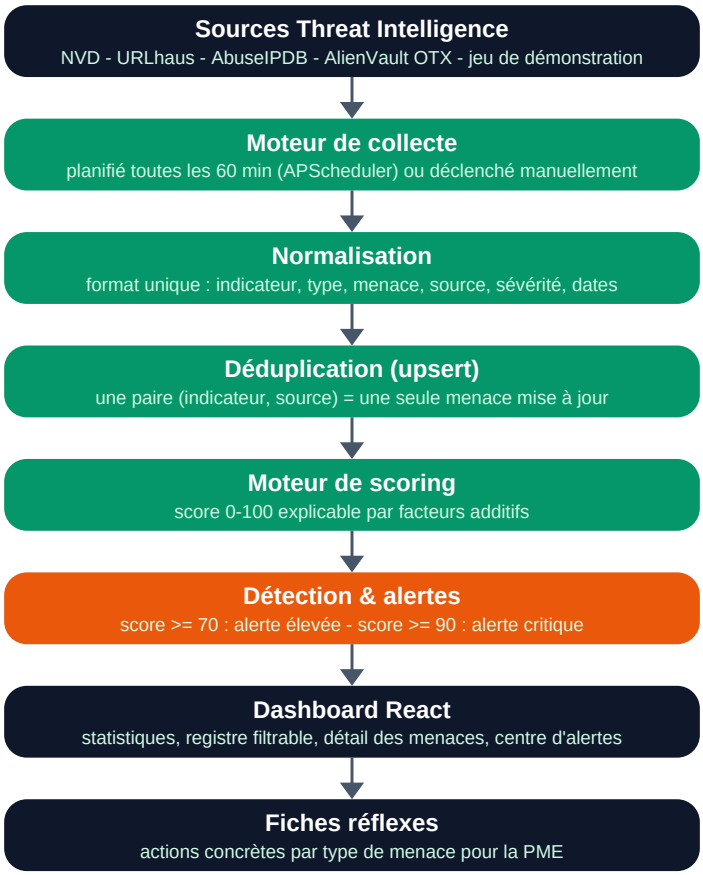
Sentinel PME répond à ce besoin : c'est une plateforme web légère de **Threat Intelligence** qui collecte des indicateurs de compromission depuis des sources publiques reconnues, les normalise, leur attribue un score de risque explicable de 0 à 100, génère des alertes pour les menaces élevées et critiques, et propose des fiches réflexes adaptées aux capacités d'une PME. Il s'agit d'un système d'alerte précoce de type « SIEM-light » : il ne remplace pas un SIEM complet (Splunk, QRadar, Wazuh) et ne collecte pas les journaux internes des machines.

1.1 Acteurs et rôles

Rôle	Code	Permissions
Administrateur	admin	Accès complet : consultation, analyse de menaces, collecte, acquittement des alertes, création et gestion des comptes utilisateurs.
Analyste cybersécurité	analyst	Consultation, analyse et ajout de menaces, déclenchement des collecteurs, acquittement des alertes, consultation des fiches réflexes.
Responsable PME	viewer	Lecture seule : dashboard global, alertes importantes, recommandations et état général des risques.

2. Fonctionnement du système

Le système fonctionne comme un pipeline de traitement continu : les données brutes de Threat Intelligence entrent d'un côté, des alertes actionnables et des recommandations sortent de l'autre.



2.1 Collecte

Chaque source dispose d'un collecteur dédié qui interroge son API, applique une limite de résultats et transforme les réponses hétérogènes en un format normalisé unique (*ThreatInput*). La collecte s'exécute automatiquement toutes les 60 minutes (configurable via `COLLECTOR_INTERVAL_MINUTES`) et peut aussi être déclenchée à la demande depuis la page « Sources » du dashboard ou via l'API. Une source en panne n'interrompt jamais les autres.

Source	Données collectées	Clé API	Utilité pour la PME
NVD (NIST)	CVE récentes avec score CVSS	Optionnelle	Identifier les vulnérabilités critiques à corriger
URLhaus (abuse.ch)	URLs de distribution de malware	Non	Bloquer les liens malveillants actifs
AbuseIPDB	IP malveillantes (confiance >= 90 %)	Oui	Bloquer les IP hostiles au pare-feu
AlienVault OTX	IOCs des pulses suivies (IP, domaines, URLs, hashes, CVE)	Oui	Veille communautaire multi-indicateurs
Sample (local)	Jeu de démonstration réaliste	Non	Démonstration et tests sans dépendance externe

2.2 Scoring de risque

Le score est la somme bornée à 100 de facteurs additifs, ce qui le rend **explicable** : chaque menace peut justifier son score facteur par facteur.

Facteur	Points attribués
Sévérité annoncée par la source	low : 5 - medium : 20 - high : 35 - critical : 50
Type d'indicateur	IP : 5 - domaine : 7 - URL : 8 - hash : 6 - CVE : 12 (+5 de bonus)
Type de menace	ransomware : 18 - malware/vulnérabilité : 12 - phishing : 10 - brute force : 8 - IP suspecte : 7
Fiabilité de la source	NVD : 12 - URLhaus : 11 - AbuseIPDB/OTX : 9 - manuel/sample : 4
Exploitation active connue	+15
Ciblage connu des PME	+10
Récence (première observation)	moins de 7 j : +8 - moins de 30 j : +5 - moins de 90 j : +2

0 - 39	40 - 69	70 - 89	90 - 100
FAIBLE	MOYEN	ÉLEVÉ	CRITIQUE

Seuils de conversion du score en niveau de risque.

2.3 Alertes

- **score >= 90** : une alerte de niveau **critique** est créée automatiquement ;
- **score >= 70** : une alerte de niveau **élevé** est créée automatiquement ;
- une menace donnée ne génère qu'une seule alerte (pas de spam lors des collectes répétées) ;
- les analystes et administrateurs peuvent **acquitter** une alerte traitée ;
- canal actuel : dashboard avec historique — canaux futurs : email, Telegram, Slack, webhook.

3. Fonctionnalités

3.1 Vue d'ensemble

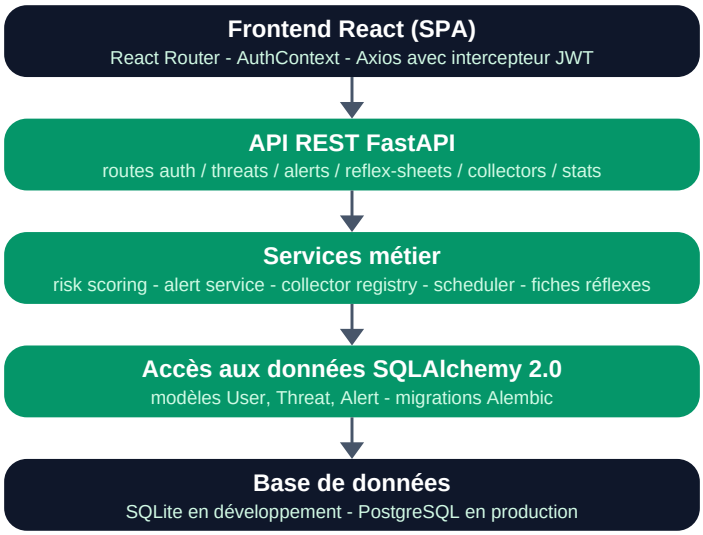
Module	Description
Authentification & RBAC	Connexion par email/mot de passe, jetons JWT signés (HS256, expiration 8 h), trois rôles avec permissions différenciées, création de comptes par l'administrateur.
Collecte Threat Intelligence	Cinq collecteurs normalisés, planification automatique (APScheduler), déclenchement manuel par source, suivi de l'état de chaque source (menaces collectées, dernière collecte, clé configurée).
Moteur de scoring	Score 0-100 explicable, conversion automatique en niveau de risque, prise en compte du contexte PME (ciblage, exploitation active, récence).
Classification	Typage des menaces : phishing, malware, ransomware, brute force, vulnérabilité, IP suspecte, inconnu.
Déduplication	Contrainte d'unicité (indicateur, source) en base et logique d'upsert : les collectes répétées mettent à jour la menace existante au lieu de la dupliquer.
Alertes	Génération automatique selon les seuils, alerte de test, acquittement par analyste/admin, historique consultable.
Fiches réflexes	Plans d'action concrets pour 7 types de menaces : bloquer, isoler, vérifier les sauvegardes, activer la MFA, appliquer les correctifs, escalader.
Dashboard	Vue d'ensemble avec statistiques temps réel, registre des menaces filtrable (risque, type, source, recherche libre), détail d'une menace avec score et fiche réflexe, centre d'alertes, page sources, à propos.
Analyse manuelle	Un analyste peut soumettre un indicateur (IP, domaine, URL, CVE, hash) pour analyse et scoring immédiats.

3.2 Pages du dashboard

Page	Contenu	Accès
Connexion	Formulaire email / mot de passe, obtention du jeton JWT	Public
Vue d'ensemble	Compteurs par niveau de risque, derniers indicateurs, alertes récentes	Tous rôles
Menaces	Tableau filtrable et paginé avec total réel (en-tête X-Total-Count)	Tous rôles
Détail d'une menace	Score, barre de risque, informations techniques, fiche réflexe numérotée	Tous rôles
Alertes critiques	Liste des alertes, génération de test, bouton d'acquittement	Acquittement : admin/analyste
Fiches réflexes	Plans d'action par type de menace	Tous rôles
Sources	État des 5 collecteurs et déclenchement manuel de la collecte	Collecte : admin/analyste
À propos	Présentation du projet et de son périmètre	Tous rôles

4. Architecture logicielle

4.1 Vue en couches



Le backend est organisé en couches strictes : les routes HTTP ne contiennent aucune logique métier (elles valident, délèguent aux services et sérialisent), les services encapsulent le scoring, la collecte et les alertes, et l'accès aux données passe exclusivement par SQLAlchemy. Le frontend est une SPA React qui consomme l'API via Axios ; un intercepteur attache automatiquement le jeton JWT et déconnecte l'utilisateur en cas de réponse 401.

4.2 Organisation du code

```
backend/app/
  main.py                   application FastAPI, middlewares, seed, cycle de vie
  core/      config.py      configuration Pydantic Settings (.env)
             security.py    hachage bcrypt, création/décodage JWT
             deps.py        get_current_user, require_roles (RBAC)
             rate_limit.py  limiteur de débit slowapi
  models/    user.py / threat.py / alert.py       modèles SQLAlchemy
  schemas/   user.py / threat.py / alert.py       schémas Pydantic
  api/       routes_auth.py / routes_threats.py / routes_alerts.py
             routes_reflex.py / routes_collectors.py
  services/  risk_scoring.py / threat_service.py / alert_service.py
             collector_registry.py / scheduler.py / reflex_sheets.py
  collectors/ base.py + sample / urlhaus / nvd / abuseipdb / otx
backend/alembic/            migrations de schéma
backend/tests/              12 tests pytest (API, RBAC, scoring, upsert)

frontend/src/
  main.tsx / App.tsx        point d'entrée, routage et garde d'authentification
  auth/      AuthContext.tsx  contexte global (login, logout, rôle)
             storage.ts       persistance du jeton (localStorage)
  api/       client.ts        client Axios + intercepteurs JWT/401
  components/ Layout, ProtectedRoute, RiskBadge, StatCard, StateViews
  pages/     Login, Overview, Threats, ThreatDetails, Alerts,
             ReflexSheets, Sources, About
  types/     index.ts         types TypeScript partagés
  test/ + *.test.tsx          9 tests Vitest / React Testing Library
```

4.3 Modèle de données

Entité	Champs principaux	Rôle
Threat	id (UUID), indicator, indicator_type, threat_type, source, severity, risk_score, risk_level, description, recommended_action, first_seen, last_seen, created_at — unicité (indicator, source)	Menace normalisée et scorée
Alert	id (UUID), threat_id (FK, cascade), level, title, message, channel, acknowledged, created_at	Alerte générée pour les menaces à score >= 70
User	id (UUID), email (unique), hashed_password (bcrypt), role, is_active, created_at	Compte utilisateur et rôle RBAC
ReflexSheet	threat_type, title, actions[] (référentiel applicatif)	Plan d'action par type de menace

4.4 API REST

Méthode	Endpoint	Accès
POST	/api/auth/login	Public (renvoie le JWT)
GET	/api/auth/me	Authentifié
POST / GET	/api/auth/users	Admin
GET	/health, /	Public
GET	/api/stats	Authentifié
GET	/api/threats (filtres + X-Total-Count)	Authentifié
GET	/api/threats/{id}, /api/threats/critical	Authentifié
POST	/api/threats/analyze, /api/threats/manual	Admin/Analyste — 30/min
GET	/api/alerts	Authentifié
POST	/api/alerts/test	Admin/Analyste — 10/min
PATCH	/api/alerts/{id}/acknowledge	Admin/Analyste
GET	/api/reflex-sheets, /api/reflex-sheets/{type}	Authentifié
GET	/api/collectors	Authentifié
POST	/api/collectors/{name}/run	Admin/Analyste — 6/min

La documentation interactive OpenAPI (Swagger UI) est générée automatiquement sur /docs.

5. Stack technologique

Couche	Technologies	Rôle
Backend	Python 3.12+, FastAPI, Pydantic v2, Uvicorn	API REST asynchrone, validation stricte des entrées/sorties
Persistance	SQLAlchemy 2.0, SQLite (dev), PostgreSQL (prod), Alembic	ORM typé, migrations de schéma versionnées
Sécurité backend	PyJWT, bcrypt, slowapi, python-multipart	Jetons JWT, hachage des mots de passe, limitation de débit
Collecte	httpx (client HTTP async), APScheduler	Interrogation des APIs de Threat Intelligence, planification
Frontend	React 19, TypeScript, Vite 7, React Router 7	SPA typée avec routage protégé par authentification
UI	Tailwind CSS, lucide-react	Design system utilitaire, iconographie
Client HTTP	Axios (intercepteurs JWT et 401)	Communication avec l'API
Tests	pytest (12 tests), Vitest + React Testing Library (9 tests)	Tests API/RBAC/scoring côté backend, composants et flux côté frontend
CI/CD	GitHub Actions : tests, lint, build, pip-audit, bandit, npm audit, gitleaks	Intégration continue avec scans de sécurité
Déploiement	Docker (image non-root, migrations au démarrage), Docker Compose, Nginx	Conteneurisation reproductible, reverse proxy du frontend

6. Sécurité

S'agissant d'une plateforme de cybersécurité, l'application applique elle-même les bonnes pratiques qu'elle recommande :

- **Authentification JWT** signée HS256 avec expiration (8 h), mots de passe hachés en **bcrypt** avec sel ;
- **Contrôle d'accès par rôle (RBAC)** sur chaque endpoint sensible : lecture pour tous les rôles authentifiés, écriture réservée aux admins/analystes, gestion des comptes réservée à l'admin ;
- **Limitation de débit** (slowapi) sur tous les endpoints d'écriture pour empêcher l'empoisonnement de données et les abus (30/min pour l'analyse, 10/min pour les alertes de test, 6/min pour la collecte) ;
- **En-têtes de sécurité** sur toutes les réponses : Content-Security-Policy, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy, et HSTS en production ;
- **CORS restreint** aux origines configurées, méthodes et en-têtes limités ;
- **Aucun secret dans le code** : configuration via .env (ignoré par git), la clé JWT par défaut est refusée en production ;
- **Validation stricte des entrées** avec Pydantic (types énumérés, longueurs maximales, emails) ;
- **Chaîne CI sécurisée** : audit des dépendances (pip-audit, npm audit), analyse statique de sécurité (bandit), détection de secrets committés (gitleaks) ;
- **Conteneur durci** : l'image Docker backend s'exécute avec un utilisateur non-root et applique les migrations Alembic au démarrage ;
- **Déduplication en base** : contrainte d'unicité garantissant l'intégrité même en cas de collectes concurrentes.

7. Tests et qualité

Périmètre	Outils	Couverture
Backend (12 tests)	pytest + TestClient FastAPI	Santé de l'API, authentification obligatoire, RBAC (viewer refusé en écriture), analyse et scoring, upsert sans doublon, menaces critiques, fiches réflexes, cycle de vie des alertes (création + acquittement), liste et exécution des collecteurs, statistiques
Scoring (unitaires)	pytest	Bornage du score à 100, explicabilité des facteurs, seuils de conversion 39/40/70/90
Frontend (9 tests)	Vitest + React Testing Library	RiskBadge (libellés FR), StatCard, page de connexion (succès et échec), acquittement d'alerte, masquage des actions d'écriture pour le rôle viewer
Intégration continue	GitHub Actions	5 jobs : tests backend, sécurité backend (pip-audit + bandit), lint + tests + build frontend, audit npm, scan de secrets gitleaks

Vérification de bout en bout effectuée en conditions réelles : connexion admin, collecte réelle depuis NVD, AbuseIPDB et OTX (77 menaces), pagination avec total, acquittement d'alerte, refus 401/403 vérifiés, limitation de débit confirmée (429 au 11e appel), en-têtes de sécurité présents.

8. Limites du MVP et évolutions prévues

Limites assumées du MVP	Évolutions prévues
Pas de SIEM complet ni de corrélation de journaux internes ; pas d'agents sur les postes ; dépendance à la disponibilité des sources publiques ; alertes limitées au dashboard ; pas encore de gestion des comptes dans l'interface.	Notifications email / Telegram / Slack / webhook ; corrélation multi-sources plus fine ; modèle Machine Learning (scikit-learn) en complément du scoring à règles ; Elasticsearch/Kibana pour les gros volumes ; interface d'administration des utilisateurs ; rapports PDF automatiques.